

Technical Director: Mark Boutwell - maboutw@radium.ncsc.mil



Brian Ricks - bwr031000@utdallas.edu

Table of Contents

1 Project Summary	2
1.1 Project Description	2
1.2 Estimated Project Budget	2
1.3 Timeline of Milestones	2
1.4 Specific Aims	2
2 Executive Summary	3
3 Previous Work	3
3.1 Data Masking	3
3.2 Computing on Masked Data (CMD)	4
3.2.1 The Advent of CMD	4
3.2.2 Another approach for CMD	4
4 Motivation	5
5 Research Project Plan and Approach	6
5.1 Research Project Phases	6
5.2 Resources Required	6
6 Current Progress	6
6.1 Encryption	7
6.2 Substitution	7
6.3 Shuffling	8
6.4 Nulling Out	8
6.5 Masking Out	8
6.6 Policy-Based Data Masking	9
7 Deliverables	9
8 Anticipated Issues and Challenges	10
9 Investigator Biographies	10
10 Bibliography	12

1 Project Summary

1.1 Project Description

With privacy preservation becoming an increasingly challenging problem, many models of masking data have been introduced. This has been accompanied by some computation approaches each having their own efficiency factors. The main goal of this project is to identify approaches and designs for masking data to preserve privacy.

1.2 Estimated Project Budget

As our team does not anticipate any expenses, we do not have any project budget.

1.3 Timeline of Milestones

Key Deliverables	Due Date / Expected Completion Date
Project Proposal	September 9, 2022
Phase One - Analysis and comparison of data masking techniques	September 14, 2022
Final Midterm Presentation	October 21, 2022
Phase Two - Threat Models and Mitigations	October 21, 2022
Phase Three - Architectural Analysis	November 11, 2022
Phase Four - Computing on Masked Data	December 2, 2022
Final Report Presentation	December 2, 2022
Final Report	December 4, 2022

1.4 Specific Aims

Since the subject matter is relatively unexplored and highly advanced, we will be creating a survey paper which highlights the theories of data masking. Through this research project, our team will introduce existing data masking models and do an in-depth analysis of each model which would cover their differences, similarities, effectiveness, and efficiency. We will also look for solutions that could fix any issues in these methods along with suggesting features that increase the privacy protections for different types of system architectures. This project would assist security engineers by consolidating the details in a single paper which would further help

them apply the most optimized data masking model to protect the privacy of users based on the requirements of the system.

2 Executive Summary

With the rapid development of digital technology and the widespread popularization of the mobile Internet, more and more people's daily life and work information are digitized and collected, and used by massive mobile terminals and intelligent processing equipment, resulting in the explosive growth of the amount of data on the Internet and contributed to the arrival of the era of big data. Big data contains huge commercial value. At present, all walks of life are committed to the mining and analysis of big data. However, there are also a series of privacy issues that follow. Big data often contains a large amount of sensitive information of users. The direct release or sharing of original data without processing will inevitably lead to leakage of user privacy. In recent years, the issue of data privacy protection in the computing environment has received extensive attention. The data privacy protection models and technologies have been developed to some extent.

There are many approaches to protect the privacy of the users. However, with the increasing volume of data, more diverse data types, and increasingly complex storage systems, this means that data privacy protection models, algorithms, and related technologies are facing many problems. This includes issues associated with properly masking the data and processing the masked data to minimize the potential of leaking information. Even when masked, data can be vulnerable as it is sent and received across system and architectural boundaries.

The main goal of this project is to identify approaches and designs for masking data to preserve privacy. This project will be divided into four phases, consisting of rigorous research.

3 Previous Work

3.1 Data Masking

There are several data masking techniques to protect sensitive and private data. Some of these techniques include encryption, substitution, shuffling, nulling out, and masking out. Encryption and decryption entails the original data being encoded or modified into a new series of data by some algorithm approach. Substitution is a method to replace the existing data in the database with some random values that look real and are of the same type as the original data. Shuffling ensures that there are no two related data present in the same row [1]. The advantage of shuffling over substitution is that generating random unique values is not necessary. Nulling out or Deletion replaces the sensitive data fields with NULL values. Masking out means replacing

certain parts of the data with specific characters(X or *). For example, the credit card number 5289 7895 1236 4598 can be masked as 5289 XXXX XXXX 4598 [2].

3.2 Computing on Masked Data (CMD)

The above approaches for data masking require that the data be decrypted for it to be used inside the big data system, which requires that the keys to the data be available to the big data system thus exposing the data to any attacker able to breach the boundaries of the system. Therefore, some research groups developed approaches for the Computing on Masked Data (CMD) method to perform computations directly on masked data and ensure that only authorized recipients can unmask the data.

3.2.1 The Advent of CMD

Data veracity is becoming a research hotspot of big data and there have been a lot of related studies. Some cryptography techniques have been used to ensure the data veracity, however, in the context of big data systems, some traditional encryption mechanisms may be more computationally expensive and inefficient than others. In 2014, a new technique, CMD, was introduced to improve data veracity while allowing a wide range of computations and queries to be performed with low overhead [3]. The CMD depends on the associative array, which includes features from both sparse matrices and database stored records. Associative arrays show complex relationships between entities and are represented as a sparse matrix or graph. Thus, the CMD performs both matrix and graph algorithms due to its structure. It combined efficient cryptographic encryption methods with an associative array representation of big data. The encryption method could be Deterministic (DET), Order-Preserving Encryption (OPE), or Fully Homomorphic Encryption (FHE), which was directly integrated into associative array environments. The CMD was evaluated using bioinformatics (DNA sequence matching algorithms) and social media data (database operations on social media). The evaluation results showed reduction of the overhead while revealing less information about the actual data, which preserves the data privacy and, as a result, its veracity.

Maintaining data veracity requires security mechanisms that are computationally inexpensive. The CMD method has shown to require less overhead time than the FHE method. It focused on the value of data and how to extract valuable information from data rather than data protection, and improved data confidentiality, integrity, and trustworthiness of big data. The limitation is that CMD techniques failed to cover the overhead during the masking process that requires more time, and the keys management requires efficient solutions.

3.2.2 Another approach for CMD

CMD combines different encryption algorithms to create a relaxed encryption scheme for masking the data. In 2015, Gadepally et al. [4] extended this schema to achieve quick access and analysis in the cloud server. It used a combination of randomized encryption (RND), DET, and OPE modes to mask sensitive data, inserting into a NoSQL database and performing simple computation on the masked data.

This scheme has four data masking steps. It first uses RND and Advanced Encryption Standard (AES) methods to make the same plaintext produce different ciphertexts. It conceals all information about the data by utilizing the AES-256 block cipher from OpenSSL and the cipher block chaining method. The key is securely generated with a user-created password, salt, and a key generation loop. A cryptographically strong string of arbitrary length is used for the initialization vector (IV). Then, the DET exposes equality patterns, as it does not require a deterministic function for generating the IV. It is based on SHA-1 to compute the hash value of each request. The OPE stores the hash values in the binary search tree. Because the hash values will not reveal the content of the original message, servers will communicate with the users to check the position in the binary search tree. Finally, the CMD provides authentication (AUT) that is used to generate the digital signature. The authentication mode leaves data in plaintext but adds a hash-based message authentication code (HMAC) to ensure data integrity. To simplify string handling, ciphertexts are converted into printable characters using Base64 encoding. These options allow for different levels of security when performing operations on the masked data, with little increased overhead in comparison to processing the plaintext data.

4 Motivation

In today's information age, the data is an important asset of the organization so the security of the data is a vital role in the industry. In order to achieve the above aspect, the data masking is used. The data masking is mainly the data that is replaced with realistic but not the original data. The main objective is to make sensitive information not made available outside of the environment. The data masking is to just provide the copy of the production data in support of the development environment and thus it controls the leakage of the data.

There are many different approaches to data masking. How to choose them in some specific environment is a question for the researchers. Also, there are many issues associated with masking data. How to improve the privacy preservation across systems is also needed to be investigated. These questions above motivate us to do research in data masking.

5 Research Project Plan and Approach

5.1 Research Project Phases

We plan to complete our research project in four phases. We would start by studying the characteristics of common masked data, the existing approaches to preserve their privacy and common attacks against this data, where we look at the issues associated with data masking and the implications of using different techniques for computing architecture. We would then create a threat model and attack vectors where we research if there are approaches to prevent the leaking of the masked data as it is processed, through the patterns and behaviors of the processor, memory, function calls and as the data is in transit, at rest or being processed. After this, we will investigate implications of using these techniques with different architectures where we research what are the necessary features to enhance privacy preservation across system and architectural boundaries. Following that, we will explore computing on the different types of masked data.

- Phase 1: Analysis and comparison of data masking techniques
- Phase 2: Threat Models and Mitigations
- Phase 3: Architectural Analysis
- Phase 4: Computing on Masked Data

5.2 Resources Required

At this time, we do not anticipate the use of any resources apart from a collection of research papers.

6 Current Progress

Data masking refers to hiding sensitive data in a database from unauthorized users. In data masking, the information is not necessarily completely hidden or removed. Instead, the data is modified so that less secret information is visible in order to protect user privacy or conform to privacy policies. The resulting data after masking resembles the real, original data and can be used for computing purposes without sharing secret information. One of the primary problems in data masking is balancing disclosure risk with data utility.

Disclosure risk refers to the likelihood of a malicious viewer being able to infer who a certain record belongs to, or the true value of a sensitive field. Data utility refers to the usefulness of the data for computing purposes. Low data utility means that analysis of the masked data may yield very different conclusions and statistical inferences than that of the original unmasked data. This trade-off of disclosure risk and data utility creates a large set of data masking techniques.

Data masking techniques can be put into two categories: static and dynamic. Static data masking, or SDM, alters data at rest. It permanently changes the original database so that there is no

unmasked sensitive data available. Using SDM means that there is no additional processing cost when performing queries as the data is already masked. SDM is often utilized for complying with privacy regulations, since it ensures that a database does not have any copies of unmasked data. Dynamic data masking, or DDM, alters data in transit. The data is masked after retrieval from the database, leaving the original database intact and masking the query results. This allows authorized users to view sensitive data, while providing masked data to unauthorized users. DDM can also be used to mimic role-based access by applying different levels or types of masking depending on the user making the request.

6.1 Encryption

Encryption is the most common and one of the oldest algorithm approaches for information security. Encryption is the encoding of text using private key algorithms. Although encrypted data appears random, encryption proceeds in a logical way, allowing a party that receives the encrypted data and possesses the right key to decrypt the data, turning it back into the original data. Highly secure encryption will use keys complex enough that an attacker is unlikely to decrypt or break the ciphertext by plain brute force, that is by guessing the key.

This means that encryption has a high cost to attack, even when the attacker knows what algorithm is used, while maintaining a very low disclosure risk. Compared to other masking methods, encryption requires greater computation overhead and hence is costlier to implement. It is also excessive in most cases, as most fields do not require this level of security. Encrypting the entire base also eliminates data utility, as it cannot be useful without decryption, unless homomorphic encryption is used (which allows computation on encrypted data without decrypting it first).

6.2 Substitution

Substitution is the technique of replacing the existing data in the database with some random values from a pre-prepared dataset that look real and are of the same type as the original data. For example, one rule could be that all first names starting with A are replaced by Aaron. The modified data may or may not be related to the original data. Doing so verifies that we achieve low disclosure risk since there could be multiple similar entries in the database. Another advantage of this technique is that the look of the data remains intact even after substitution.

The downside of the method is that the random list must be available for each column to be replaced. Thus, the system should have the ability to generate invalid but similar data with the same data type. It also means that we get a low data utility.

6.3 Shuffling

Shuffling refers to swapping data fields across different records without modifying the values of the fields themselves. The shuffling can be done on individual fields or on groups of columns to retain data consistency. For data with relationships across fields, they may be grouped to prevent shuffling from creating incorrect-looking data; for example when separate columns include a phone number and state, so that the shuffled data still remains plausible. If shuffling columns as a group is still a privacy concern, partitions can be made within groups so additional shuffling can be done without creating inconsistent data. Following the previous example, we could create a partition for each state and shuffle phone numbers across entries within the same state.

This process works best for when metrics or operations are being computed on the entire dataset, as all statistical values would remain the same.

Unfortunately most shuffling methods have a high disclosure risk, as all the original data is still in the database. As such, some sensitive information can be inferred by malicious users. For example, if every record includes a medical condition, it can be inferred that any individual user has one of the conditions in the database. Shuffling fields may also lead to low data utility if it is not done with careful grouping or when not computing on the whole dataset, as the analysis of the shuffled data may yield very different statistical values. These issues can limit the efficacy of shuffling for masking data for computing purposes.

6.4 Nulling Out

The nulling out technique just deletes sensitive data and replaces the field with NULL values. For example, we could replace a phone number with —(XXX)XXX-XXXX, or a Social Security Number (SSN) with XXX-XXXX-XX. It is a simple way of ensuring that the data is completely invisible, hence ensuring that there is no disclosure risk. However, this also means that there is no data utility for the nulled out fields. For instance, it is difficult to write and test customer account maintenance forms if the customer name address and contact details are NULL values. Therefore, nulling out is only useful in circumstances where the data is not required, or for extremely sensitive values, but is rarely useful as the entire data sanitization strategy.

6.5 Masking Out

Character scrambling or masking out of certain fields is also another simplistic yet very effective method of preventing sensitive information to be viewed. It is really an extension of nulling out, but there is a greater emphasis on keeping the data real and not fully masked all together. Masking data, besides being the generic term for the process of data anonymization, means replacing certain fields with a mask character (such as an X). This effectively disguises the data content while preserving the same omission on front end screens and reports. For example, an ecommerce call center operator might only see the last 4 digits of a customer's credit card but

once the billing system passes the customer's details for charging, the full number is revealed to the payment gateway systems.

If the data is in a specific, invariable format, then masking out is a powerful and fast option. If numerous special cases must be dealt with then masking can be slow, extremely complex to administer and can potentially leave some data items inappropriately masked. Furthermore, it should be ensured that neither too little nor too much of the data is masked. For example, if everything except the last two digits of the credit card, that would be too insecure as those digits could be easily generated by the checksum card number generation algorithm. On the other hand, if just the last two digits are masked, that would mask away important information about the card that could be needed.

6.6 Policy-Based Data Masking

Customer data is protected by data privacy laws or policies, which indicates which kind of data is sensitive, and how to protect the data. Masking is often done in order to conform to such regulations and must also be taken into consideration when identifying a technique for the situation. There are the four most common policies. California Consumer Privacy Act (CCPA) is a law that entitles Californians to know how their private data is collected, used, shared, or sold, and to withdraw their data content for future use. Customers also have the right to sue companies if the company doesn't follow security policy to protect their personal data to make them become victims of a data breach. Healthcare Insurance Portability and Accountability Act (HIPAA) is a data privacy law that protects patients' personal information against reasonably anticipated threats, such as unauthorized use or disclosure of their private data, or hazards to the integrity of protected health information. The Gramm-Leach-Bliley Act (GLB Act or GLBA) contains rules on how financial institutes collect, protect, use, and share their customers' personal and financial information, which covers data stored in physical documents and electronic or other mediums. The General Data Protection Regulation (GDPR) which states that companies must have appropriate technical and organizational measures to protect Europeans' personal data against being stolen, altered, destroyed, lost or disclosed to or accessed by unauthorized individuals while it is transmitted, stored or processed.

7 Deliverables

The following due dates for the deliverables are in accordance with the INSuRE Hub program's timeline.

Key Deliverables	Due Date / Expected Completion Date
Project Proposal	September 9, 2022
Midterm Presentation Draft	October 14, 2022

Final Midterm Presentation	October 21, 2022
Final Report Presentation	December 2, 2022
Final Report	December 4, 2022

8 Anticipated Issues and Challenges

The main challenge we anticipate at this time is the lack of previous research on the computing of data masking. With a subject matter that is relatively unexplored and highly advanced, we anticipate a slight learning curve for the team. Considering how open ended this topic is, there is a high chance that our vision could deviate from our project plan.

9 Investigator Biographies

Megan Tran is currently pursuing a masters in Computer Science with the Cybersecurity track at the University of Texas of Dallas. She has worked on web and Java development for over two years at Sandia National Laboratories. She has also interned at the Air Force Research Laboratories working in embedded systems security. At UTD, she has completed coursework in information security, network security, data & application security, language-based security, and operating systems. She is a Women in Cybersecurity scholarship recipient and has consistently placed in the top 10% of participants at National Cyber League competitions.

Saloni Shivdasani is a masters student at the University of Texas at Dallas majoring in Computer Science with a concentration in cyber security. She has been in the software development industry for more than 2 years. At her current job at a consulting firm, she has been utilizing skills in project management, cloud administration, continuous integration and delivery on the cloud and full stack mobile development. She also has had a year of experience as an Engineering Analyst at the Information Security Office at UTD utilizing cloud administration along with Python and shell automation. While at UTD, she had taken classes pertaining to information security, data and application security, network security, and language based security along with database systems, telecommunication systems, advanced operating systems and software testing. Outside of university and work, she has taken part in security competitions where she has consistently placed in among the top 10% nationally and received scholarships to attend multiple conferences. She is currently studying to get her security+ credentials.

Yingyuan Jiang is a master student with a GPA of 3.81/4.0 at UTD majoring in Computer Science with a track in Data Science. He has four years of industrial and academic experience as a software developer on cloud platforms with 3 published papers about security and 12 patents. In the previous experience, he designed the database and website on Alibaba Cloud(the biggest cloud platform in China) for a technology company. He was selected from thousands of

candidates to be voluntarily a student expert in Alibaba Security to make contributions to projects related to security risk because he got 2nd place of 2520 teams in IJCAI-2019 Alibaba Adversarial AI Challenge (AAAC 2019), an international attack-and-defense competition, where he applied encode-and-decode architecture to train models using masking image data to defend against the attack. In 22' Summer, he did an internship in a local company in Dallas, Texas and worked on the projects about database design and backup related to customers' private data. Also, he has taken courses, such as Database Design, Big Data Management and Analytics, Web Programming. He is comfortable with Java and Python.

Hua Xiao is currently a master student with GPA of 4.0/4.0 in Computer Science at the University of Texas at Dallas on the Intelligent Systems Track. She has received a PhD degree from Virginia Tech and has 8 years of industrial and academic experience in the Biotechnology area. Her background experience is related to the biosecurity and biosafety based on modern biotechnics in agriculture and food production with 3 published papers in the peer-reviewed journals. She is now doing an internship in a local company in Plano, Texas and working on the projects about web application development and QA testing. She has taken coursework for Information Security, Machine Learning, Database Design, Algorithm Design, Operating Systems, Big Data Management and Analysis and Computer Architecture. She has a strong background in Python and some experience in Java, MIPS, HTML/CSS, JavaScript and PHP.

10 Bibliography

- [1] Xiao-Bai Li and Luvai Motiwalla , “Protecting Patient Privacy with Data Masking” , WISP, 2009.
- [2] Ambrosia, Vincent G., et al. "An integration of remote sensing, GIS, and information distribution for wildfire detection and management." *Photogrammetric Engineering and Remote Sensing* 64 (1998): 977-986.
- [3] J. Kepner et al., “Computing on masked data: a high performance method for improving big data veracity,” in 2014 IEEE High Performance Extreme Computing Conference (HPEC), Waltham, MA, USA, Sep. 2014, pp. 1–6. doi: [10.1109/HPEC.2014.7040946](https://doi.org/10.1109/HPEC.2014.7040946).
- [4] V. Gadepally et al., “Computing on Masked Data to improve the security of big data,” in 2015 IEEE International Symposium on Technologies for Homeland Security (HST), Waltham, MA, USA, Apr. 2015, pp. 1–6. doi: [10.1109/THS.2015.7225312](https://doi.org/10.1109/THS.2015.7225312).

